
Seguridad en Sistemas Agénticos

Módulo 12 · Seguridad en IA

Memory poisoning, tool misuse, SSRF, regla Meta de controles fuera del LLM y checklist de seguridad agéntica.

1. Introducción · 2. Qué es · 3. Cómo funciona · 4. Ejemplos reales
5. Errores comunes · 6. Aplicación práctica · 7. Relación con módulos · 8. Resumen ejecutivo

Guía de estudio detallada · +2.000 palabras

Seguridad en Sistemas Agénticos

Los sistemas agénticos de IA amplían dramáticamente la superficie de ataque respecto a los LLMs de chat: los agentes tienen herramientas que modifican el estado del mundo, acceso a datos sensibles en múltiples sistemas, y pueden ejecutar cadenas de acciones de múltiples pasos antes de que un humano intervenga. Una prompt injection exitosa en un agente no solo produce un output de texto incorrecto: puede desencadenar una cadena de acciones irreversibles en sistemas de producción. George Kurtz (CEO de CrowdStrike) lo expresó de forma directa en FalCon 2025: "Un agente de IA es como darle a un becario acceso completo a tu red. Tienes que ponerle algunos guardrails al becario."

En 2025, OWASP publicó un Top 10 separado específicamente para sistemas agénticos de IA, reconociendo que el perfil de riesgo es fundamentalmente distinto al de los LLMs de chat. Los investigadores de seguridad han catalogado 15 categorías de amenazas únicas para sistemas agénticos (Rippling, 2025), incluyendo memory poisoning, tool misuse, y privilege compromise. El 35% de las organizaciones identifican los riesgos de ciberseguridad como su principal barrera para adoptar la IA agéntica (Digital Commerce 360).

El mapa de amenazas para sistemas agénticos

Memory poisoning: contaminar la memoria del agente

Los agentes con memoria persistente (a corto o largo plazo) son vulnerables al memory poisoning: introducir información falsa en la memoria del agente para influir en decisiones futuras. Si el agente guarda en memoria que "el usuario X es el CEO y tiene permiso para aprobar cualquier acción", un atacante que puede escribir en la memoria del agente puede escalar privilegios permanentemente. Las memorias recuperadas de bases vectoriales son especialmente vulnerables: un documento con información falsa en el corpus puede ser recuperado como "memoria" y presentado como hechos establecidos.

Tool misuse: herramientas como vector de ataque

Las herramientas del agente son el vector de mayor riesgo: un agente comprometido con acceso a herramientas de acción puede causar daño real. Los vectores de tool misuse son: prompt injection que hace que el agente invoque herramientas con parámetros maliciosos (eliminar archivos en lugar de leer archivos), privilege escalation (usar una herramienta de bajo riesgo para obtener acceso a una herramienta de alto riesgo), y SSRF (Server-Side Request Forgery: usar la herramienta de fetch de URL del agente para acceder a servicios internos protegidos).

Privilege compromise en sistemas multi-agente

En sistemas multi-agente, la cadena de confianza entre agentes es un vector crítico. Si el Agente A confía implícitamente en el Agente B, un atacante que compromete el Agente B puede usar esa confianza para comprometer el Agente A. La solución es tratar cada agente como un

principal de confianza limitada, verificando sus solicitudes con los mismos criterios que se aplicarían a un usuario externo, no con los criterios que se aplicarían a un sistema interno de plena confianza.

SECCIÓN 3 · CÓMO FUNCIONA

Framework de seguridad para agentes

Mínimo privilegio para herramientas

Principio de mínimo privilegio aplicado a agentes: cada agente debe tener acceso solo a las herramientas y permisos estrictamente necesarios para su tarea específica. Un agente de análisis de datos solo necesita herramientas de lectura (no escritura). Un agente de generación de reportes no necesita acceso a sistemas de producción. Un agente de soporte al cliente no necesita acceso a los datos de todos los clientes. Diseña la lista de herramientas de cada agente como si estuvieras definiendo los permisos de un empleado nuevo: el mínimo necesario para hacer el trabajo.

Validación de parámetros de herramientas fuera del LLM

La validación de los parámetros que el LLM pasa a las herramientas debe realizarse en el código de la herramienta, independientemente de las instrucciones del LLM. Si la herramienta `delete_file` solo debe poder eliminar archivos en el directorio `/tmp/agent_workspace`, esa restricción debe estar en el código de la herramienta (path validation), no solo en las instrucciones del system prompt. Las restricciones implementadas solo en el prompt pueden ser eludidas con prompt injection.

Audit logging completo de acciones del agente

En sistemas agénticos, el audit logging es especialmente crítico porque las acciones son ejecutadas en sistemas externos y pueden tener consecuencias irreversibles. El log de auditoría de un agente debe incluir: cada herramienta invocada, con sus parámetros exactos, el razonamiento del agente que llevó a invocarla (el "thought" del paso ReAct), el resultado de la invocación, el usuario y la sesión que desencadenó la acción, y el timestamp. Este log permite reconstruir cualquier incidente de seguridad y demostrar qué acciones tomó el agente y por qué.

SECCIÓN 4 · EJEMPLOS REALES

- Indirect injection en agente de email con acceso a calendario (demostración de investigadores, 2024): un email malicioso contenía instrucciones para que el agente creara un evento de calendario cancelando la reunión más importante de la semana y enviara un email de disculpas falso a los participantes. El agente siguió las instrucciones porque el email parecía ser de un colega de trabajo (spoofing del remitente). Sin validación del remitente del email como instrucción confiable, el agente ejecutó las acciones.
- SSRF via agente de búsqueda web (proof of concept, 2025): un investigador demostró que un agente con herramienta de fetch de URL podía ser instruido via prompt injection a hacer peticiones a las rutas de metadatos de AWS (`169.254.169.254/latest/meta-data/`) que devuelven las credenciales de la instancia EC2. El agente con prompt injection actuaba como proxy para el atacante para acceder a servicios internos protegidos.

- Exfiltración de memoria en asistente personal (investigación de privacidad, 2025): un paper de febrero 2025 demostró que la memoria de los agentes puede ser exfiltrada a través de prompt injection indirecta. Si el agente procesa un documento malicioso que contiene instrucciones para incluir datos de la memoria del agente en el siguiente resumen que el agente genera, el atacante puede obtener acceso a información almacenada en la memoria del agente (preferencias del usuario, historial de conversaciones, información confidencial).

SECCIÓN 5 · ERRORES Y MALENTENDIDOS COMUNES

Error 1: Confiar en las instrucciones del agente sin verificación de origen. En sistemas multi-agente, un agente no debe ejecutar instrucciones de otro agente sin verificar que las instrucciones son legítimas. Un agente puede haber sido comprometido y estar emitiendo instrucciones maliciosas. Trata las instrucciones de otros agentes como las instrucciones de un usuario externo: con la misma desconfianza y con los mismos mecanismos de validación.

Error 2: Dar a los agentes acceso a herramientas de escritura en sistemas de producción desde el inicio. Empieza con herramientas de solo lectura y amplía el acceso gradualmente a medida que la confianza en el agente se acumula con evidencia de comportamiento correcto en producción. El principio de autonomía graduada del M11-T5 aplica directamente a la expansión de herramientas del agente.

Error 3: No implementar kill switches para agentes en producción. Un agente en producción debe tener siempre un mecanismo para ser detenido inmediatamente si se detecta comportamiento malicioso o inesperado. El kill switch (desactivar el agente y revocar todos sus accesos) debe ser accesible para el equipo de operaciones sin necesidad de desplegar código nuevo.

SECCIÓN 6 · APLICACIÓN PRÁCTICA

El checklist de seguridad para agentes en producción: lista de herramientas con mínimo privilegio. Validación de parámetros en el código de cada herramienta. Restricciones de path/scope en herramientas de filesystem y URL. HITL para acciones irreversibles o de alto impacto. Audit logging completo de todas las invocaciones de herramientas con timestamps y razonamiento. Kill switch accesible al equipo de operaciones. Monitorización de patrones de uso anómalo de herramientas. No confiar en instrucciones de otros agentes sin verificación. Red teaming específico de los vectores de ataque agéntico (prompt injection en herramientas, SSRF, memory poisoning).

Para implementar mínimo privilegio en herramientas con LangGraph: define la lista de herramientas en el nodo del agente como un argumento de configuración, no como una variable global. Para distintos tipos de usuarios o niveles de confianza, instancia el agente con distintos subconjuntos de herramientas. Para implementar validación de parámetros: añade una capa de validación en la función de cada herramienta que verifique que los parámetros son del tipo esperado, están dentro del rango permitido, y respetan las restricciones de seguridad antes de ejecutar la acción.

SECCIÓN 7 · RELACIÓN CON OTROS MÓDULOS

- M10-T3 (Tool use): las herramientas son el principal vector de ataque en sistemas agénticos.
- M11-T5 (Autonomía graduada): el principio de autonomía graduada aplica directamente al nivel de acceso a herramientas.
- M10-T9 (HITL): el HITL es la defensa más robusta contra prompt injection en acciones agénticas de alto impacto.

SECCIÓN 8 · RESUMEN EJECUTIVO

Los sistemas agénticos amplían la superficie de ataque: los agentes tienen herramientas que modifican el mundo real. Las amenazas específicas son: memory poisoning (datos falsos en la memoria), tool misuse (herramientas invocadas con parámetros maliciosos), privilege escalation, SSRF via tool de URL fetch, y exfiltración de memoria. La regla Meta (oct 2025): los controles deben vivir en la capa de ejecución, no en el prompt. El checklist de seguridad agéntica: mínimo privilegio en herramientas, validación de parámetros en el código de cada herramienta, HITL para acciones irreversibles, audit logging completo, kill switch accesible. El OWASP Top 10 para Aplicaciones Agénticas (2025) es la referencia específica.